

Amber & Grain

API Security Testing Dossier

Complete endpoint inventory for individual security review

Service: @amber/api (NestJS 10 + Prisma 6)
Base URL: http://<host>:3001
Tenant scope: X-Tenant-Slug header (or ?tenant= for SSE)
Auth: Authorization: Bearer <JWT>
Generated: July 2, 2026

Contents

1	Conventions & global notes	3
2	Endpoint index	3
3	Health	6
3.1	GET /health	6
4	Auth	6
4.1	POST /auth/login	6
4.2	POST /auth/select-tenant	6
4.3	GET /auth/me	6
4.4	POST /auth/change-password	7
4.5	POST /auth/sync-profile	7
5	Tenant	7
5.1	GET /tenant	7
5.2	PATCH /tenant	7
5.3	GET /tenants/:slug	8
6	Menu	8
6.1	GET /menu	8
6.2	POST /menu/upload	8
6.3	POST /menu/categories	9
6.4	PATCH /menu/categories/:id	9
6.5	DELETE /menu/categories/:id	9
6.6	POST /menu/items	9
6.7	PATCH /menu/items/:id	10
6.8	DELETE /menu/items/:id	10
7	Tables	10
7.1	GET /tables	10
7.2	GET /tables/qrcode/:token	10
7.3	POST /tables	11
7.4	PATCH /tables/:id	11
7.5	POST /tables/:id/qrcode	11
7.6	DELETE /tables/:id	11
8	Orders	12
8.1	SSE /orders/stream	12
8.2	GET /orders	12
8.3	GET /orders/open-table-ids	12
8.4	GET /orders/sales	12
8.5	GET /orders/analytics	13
8.6	GET /orders/:id	13
8.7	GET /orders/:id/payment	13
8.8	POST /orders/reclaim	14
8.9	POST /orders	14
8.10	POST /orders/:id/rounds	14
8.11	POST /orders/:id/items	14
8.12	PATCH /orders/:id/items/:itemId	15
8.13	POST /orders/:id/bill	15

8.14	POST /orders/:id/cancel	15
8.15	POST /orders/:id/payment	15
9	Service requests	16
9.1	SSE /service-requests/stream	16
9.2	POST /service-requests	16
9.3	GET /service-requests	16
9.4	PATCH /service-requests/:id	16
10	Roles	17
10.1	GET /roles	17
10.2	POST /roles	17
10.3	PATCH /roles/:id	17
10.4	DELETE /roles/:id	17
11	Members	18
11.1	GET /members	18
11.2	POST /members	18
11.3	PATCH /members/:id	18
11.4	DELETE /members/:id	19
12	Billing	19
12.1	GET /admin/plans	19
12.2	POST /admin/plans	19
12.3	PATCH /admin/plans/:id	19
12.4	POST /admin/tenants/:id/subscription	20
12.5	GET /admin/tenants/:id/subscription	20
12.6	PATCH /admin/tenants/:id/subscription	20
12.7	GET /billing/me	20
13	Admin (super-admin)	21
13.1	GET /admin/tenants	21
13.2	POST /admin/tenants	21
13.3	GET /admin/tenants/:id	21
13.4	PATCH /admin/tenants/:id	21
13.5	GET /admin/tenants/:id/payments	22
13.6	GET /admin/credentials	22
13.7	POST /admin/tenants/:id/reset-owner-password	22
13.8	POST /admin/impersonate	22
13.9	GET /admin/analytics	23
13.10	GET /admin/audit-log	23

1 Conventions & global notes

- **Base URL.** All paths are relative to `http://<host>:3001`.
- **Tenant scoping.** `TenantMiddleware` resolves the tenant from the `X-Tenant-Slug` header (or `?tenant=slug` for EventSource streams). `/admin/*` and `/auth/*` are excluded (cross-tenant).
- **Auth layer.** JWT-guarded routes use `@RequirePermission(...)`. Permission keys: `team.manage`, `settings.manage`, `menu.manage`, `tables.manage`, `orders.history`. Super-admin routes use Supabase auth + `SuperAdminGuard`.
- **Guest/device auth.** Some order + all service-request routes are **Public** or **Device-bound** (`X-Device-Id`) by design (deferred auth) — priority targets for the review.
- Each endpoint below has a checklist and a **Findings** slot to fill in.

2 Endpoint index

Method	Path	Auth	Detail
<i>Health</i>			
GET	/health	Public	jump →
<i>Auth</i>			
POST	/auth/login	Public	jump →
POST	/auth/select-tenant	Public (ticket)	jump →
GET	/auth/me	JWT	jump →
POST	/auth/change-password	JWT	jump →
POST	/auth/sync-profile	Supabase	jump →
<i>Tenant</i>			
GET	/tenant	Tenant hdr	jump →
PATCH	/tenant	settings.manage	jump →
GET	/tenants/:slug	Public	jump →
<i>Menu</i>			
GET	/menu	Tenant hdr	jump →
POST	/menu/upload	menu.manage	jump →
POST	/menu/categories	menu.manage	jump →
PATCH	/menu/categories/:id	menu.manage	jump →
DELETE	/menu/categories/:id	menu.manage	jump →
POST	/menu/items	menu.manage	jump →
PATCH	/menu/items/:id	menu.manage	jump →
DELETE	/menu/items/:id	menu.manage	jump →
<i>Tables</i>			
GET	/tables	tables.manage	jump →
GET	/tables/qr/:token	Public	jump →
POST	/tables	tables.manage	jump →

Method	Path	Auth	Detail
PATCH	/tables/:id	tables.manage	jump →
POST	/tables/:id/qr	tables.manage	jump →
DELETE	/tables/:id	tables.manage	jump →
<i>Orders</i>			
SSE	/orders/stream	StreamGuard	jump →
GET	/orders	tables.manage	jump →
GET	/orders/open-table-ids	Public	jump →
GET	/orders/sales	orders.history	jump →
GET	/orders/analytics	tables.manage	jump →
GET	/orders/:id	Device-bound	jump →
GET	/orders/:id/payment	tables.manage	jump →
POST	/orders/reclaim	Device-bound	jump →
POST	/orders	Device-bound	jump →
POST	/orders/:id/rounds	Device-bound	jump →
POST	/orders/:id/items	tables.manage	jump →
PATCH	/orders/:id/items/:itemId	Device/staff	jump →
POST	/orders/:id/bill	Device-bound	jump →
POST	/orders/:id/cancel	tables.manage	jump →
POST	/orders/:id/payment	Device/staff	jump →
<i>Service requests</i>			
SSE	/service-requests/stream	StreamGuard	jump →
POST	/service-requests	Public	jump →
GET	/service-requests	tables.manage	jump →
PATCH	/service-requests/:id	tables.manage	jump →
<i>Roles</i>			
GET	/roles	team.manage	jump →
POST	/roles	team.manage	jump →
PATCH	/roles/:id	team.manage	jump →
DELETE	/roles/:id	team.manage	jump →
<i>Members</i>			
GET	/members	team.manage	jump →
POST	/members	team.manage	jump →
PATCH	/members/:id	team.manage	jump →
DELETE	/members/:id	team.manage	jump →
<i>Billing</i>			
GET	/admin/plans	Super-admin	jump →
POST	/admin/plans	Super-admin	jump →
PATCH	/admin/plans/:id	Super-admin	jump →
POST	/admin/tenants/:id/subscription	Super-admin	jump →
GET	/admin/tenants/:id/subscription	Super-admin	jump →
PATCH	/admin/tenants/:id/subscription	Super-admin	jump →

Method	Path	Auth	Detail
GET	/billing/me	JWT	jump →
<i>Admin (super-admin)</i>			
GET	/admin/tenants	Super-admin	jump →
POST	/admin/tenants	Super-admin	jump →
GET	/admin/tenants/:id	Super-admin	jump →
PATCH	/admin/tenants/:id	Super-admin	jump →
GET	/admin/tenants/:id/payments	Super-admin	jump →
GET	/admin/credentials	Super-admin	jump →
POST	/admin/tenants/:id/reset-owner-pa	Super-admin	jump →
POST	/admin/impersonate	Super-admin	jump →
GET	/admin/analytics	Super-admin	jump →
GET	/admin/audit-log	Super-admin	jump →

3 Health

GET /health

Auth: Public

Purpose: Liveness probe.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

4 Auth

POST /auth/login

Auth: Public

Purpose: Email+password login; returns JWT or a tenant-select ticket.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /auth/select-tenant

Auth: Public (5-min ticket)

Purpose: Redeem tenant-select ticket for a scoped JWT.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /auth/me

Auth: JWT + JwtAuthGuard

Purpose: Current authenticated user.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)

- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /auth/change-password

Auth: JWT + `JwtAuthGuard`

Purpose: Change own password.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /auth/sync-profile

Auth: Supabase auth

Purpose: Ensure a Prisma User row for a Supabase super-admin sign-in.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

5 Tenant

GET /tenant

Auth: Tenant header

Purpose: Active tenant config (theme/profile).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /tenant

Auth: JWT + `settings.manage`

Purpose: Update own tenant's branding/profile.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /tenants/:slug

Auth: **Public**

Purpose: Public tenant lookup by slug (guest boot / theming).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

6 Menu

GET /menu

Auth: Tenant header

Purpose: Full menu (categories + items + modifiers).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /menu/upload

Auth: JWT + `menu.manage`

Purpose: Multipart item-photo upload → Supabase Storage.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /menu/categories**Auth:** JWT + menu.manage**Purpose:** Create category.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /menu/categories/:id**Auth:** JWT + menu.manage**Purpose:** Rename/reorder category.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

DELETE /menu/categories/:id**Auth:** JWT + menu.manage**Purpose:** Delete category (blocked if it holds items).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /menu/items**Auth:** JWT + menu.manage**Purpose:** Create item (with modifier groups).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /menu/items/:id**Auth:** JWT + menu.manage**Purpose:** Update item (replace-on-save modifiers).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

DELETE /menu/items/:id**Auth:** JWT + menu.manage**Purpose:** Delete item.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

7 Tables

GET /tables**Auth:** JWT + tables.manage**Purpose:** Floor list + status + live session.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /tables/qr/:token**Auth:** **Public****Purpose:** Resolve a table by its QR token (guest boot).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /tables

Auth: JWT + `tables.manage`

Purpose: Create table (mints qrToken).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /tables/:id

Auth: JWT + `tables.manage`

Purpose: Update table.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /tables/:id/qr

Auth: JWT + `tables.manage`

Purpose: Regenerate QR token (invalidates old).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

DELETE /tables/:id

Auth: JWT + `tables.manage`

Purpose: Delete table.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload

☐ Rate limiting / abuse

Findings: *(pending)*

8 Orders

SSE `/orders/stream`

Auth: OrderStreamGuard (`?tenant=`)

Purpose: Per-tenant SSE live floor event bus.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET `/orders`

Auth: JWT + `tables.manage`

Purpose: Live order list (`?status=`).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET `/orders/open-table-ids`

Auth: **Public**

Purpose: Table ids with a live order (guest occupancy check).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET `/orders/sales`

Auth: JWT + `orders.history`

Purpose: Sales feed / order history (`?from=&to=`).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /orders/analytics

Auth: JWT + `tables.manage`

Purpose: Aggregated revenue/orders analytics.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /orders/:id

Auth: Device-bound (`X-Device-Id`)

Purpose: Single order (guest device-bound / staff).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /orders/:id/payment

Auth: JWT + `tables.manage`

Purpose: Payment record for an order.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders/reclaim**Auth:** Device-bound (X-Device-Id)**Purpose:** Reclaim a device's live session.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders**Auth:** Device-bound (X-Device-Id)**Purpose:** Open a table session (occupancy + format guards).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders/:id/rounds**Auth:** Device-bound (X-Device-Id)**Purpose:** Add a round (server recomputes modifier deltas).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders/:id/items**Auth:** JWT + tables.manage**Purpose:** Staff add item to order.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /orders/:id/items/:itemId**Auth:** Device / staff**Purpose:** Update item qty/status (409 if order terminal).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders/:id/bill**Auth:** Device-bound (X-Device-Id)**Purpose:** Request bill (Order → billed).**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders/:id/cancel**Auth:** JWT + tables.manage**Purpose:** Staff cancel order.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /orders/:id/payment**Auth:** Device / staff**Purpose:** Capture payment; recomputes totals server-side.**Security test checklist:**

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

9 Service requests

SSE /service-requests/stream

Auth: ServiceRequestStreamGuard (?tenant=)

Purpose: Per-tenant SSE for open service requests.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /service-requests

Auth: **Public**

Purpose: Guest creates a request (dedupes on pending type).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /service-requests

Auth: JWT + tables.manage

Purpose: Staff list open requests (?status=).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /service-requests/:id

Auth: JWT + tables.manage

Purpose: Acknowledge / resolve a request.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

10 Roles

GET /roles

Auth: JWT + `team.manage`

Purpose: List custom roles.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /roles

Auth: JWT + `team.manage`

Purpose: Create role.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /roles/:id

Auth: JWT + `team.manage`

Purpose: Rename/edit role (Admin-tier guard on protected).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

DELETE /roles/:id

Auth: JWT + `team.manage`

Purpose: Delete role (blocked if protected / has members).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant

- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

11 Members

GET /members

Auth: JWT + `team.manage`

Purpose: List memberships.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /members

Auth: JWT + `team.manage`

Purpose: Add member (creates User if new).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /members/:id

Auth: JWT + `team.manage`

Purpose: Change role / permission override / activate (tier + last-admin guards).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

DELETE /members/:id

Auth: JWT + team.manage

Purpose: Remove member (last-admin + tier guards).

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

12 Billing

GET /admin/plans

Auth: Super-admin

Purpose: List billing plans.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /admin/plans

Auth: Super-admin

Purpose: Create plan.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /admin/plans/:id

Auth: Super-admin

Purpose: Update plan.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /admin/tenants/:id/subscription

Auth: Super-admin

Purpose: Create tenant subscription.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /admin/tenants/:id/subscription

Auth: Super-admin

Purpose: Get tenant subscription.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /admin/tenants/:id/subscription

Auth: Super-admin

Purpose: Update tenant subscription.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /billing/me

Auth: JWT + JwtAuthGuard

Purpose: Current tenant's own billing state.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload

☐ Rate limiting / abuse

Findings: *(pending)*

13 Admin (super-admin)

GET /admin/tenants

Auth: Super-admin

Purpose: List all tenants.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /admin/tenants

Auth: Super-admin

Purpose: Onboard a new tenant.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /admin/tenants/:id

Auth: Super-admin

Purpose: Tenant detail.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

PATCH /admin/tenants/:id

Auth: Super-admin

Purpose: Update tenant.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant

- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /admin/tenants/:id/payments

Auth: Super-admin

Purpose: Tenant payment history.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /admin/credentials

Auth: Super-admin

Purpose: Retrieve tenant credentials.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /admin/tenants/:id/reset-owner-password

Auth: Super-admin

Purpose: Reset a tenant owner's password.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

POST /admin/impersonate

Auth: Super-admin

Purpose: Mint an impersonation token for a tenant.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /admin/analytics

Auth: Super-admin

Purpose: Platform-wide analytics.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*

GET /admin/audit-log

Auth: Super-admin

Purpose: Platform audit log.

Security test checklist:

- ☐ AuthZ — access without/with wrong token or tenant
- ☐ Tenant isolation — cross-tenant object access (IDOR)
- ☐ Input validation / injection / malformed payload
- ☐ Rate limiting / abuse

Findings: *(pending)*
